Ex1: runbook for the rest of the day

One small step at a time. Do the step, tick it, move on. Do not read ahead.

If you feel stuck, do one of these (2 minutes): 1. Stand up, drink water, look away from the screen. 2. Say aloud: "The next step is ____." 3. Skip to the next task. Come back at the end. A rough answer for every topic beats a perfect answer for half of them.

Time rule: when a task's box runs out, stop where you are, tick "partly done", and move on.

Schedule (assumes you start at 12:55; slide the clock if you start later)

Start	Task	Mins	Finish by
12:55	0 Dynamic routing (only if your pack requires it)	8	13:03
13:03	5 TLS and keys	25	13:28
13:28	6 Security case	25	13:53
13:53	7 Architecture	25	14:18
14:18	8 Policy and legal	25	14:43
14:43	Justification	50	15:33
15:33	Final checks and upload	20	15:53

If you are over by 15 minutes at any point, use the cut list at the end.

Before you start (3 min)

☐ Open a notes file called **`evidence_log.txt`**. After each step, add one line: the topic number, what you did, and the screenshot name.

☐ Open the cropping tool (Snipping Tool, **`Win+Shift+S`**).

☐ Name every screenshot as you save it: **`T5_http_capture.png`**, **`T5_https_capture.png`**, and so on.

Task 0: dynamic routing (8 min, only if your pack's pass criteria say "static and dynamic routes")

This adds dynamic routing between your router and the ISP router without touching your NAT or ACLs. **Save a copy of your Packet Tracer file first.**

☐ On the company router, in global config mode:

```
router ospf 1
router-id 2.2.2.2
network 203.0.113.0 0.0.0.3 area 0
```

☐ On the ISP router:

```
router ospf 1
router-id 1.1.1.1
network 203.0.113.0 0.0.0.3 area 0
network 172.16.0.0 0.0.0.255 area 0
```

☐ Wait about 40 seconds. On the company router run **`show ip route`**. You should see a line starting **`O`** for 172.16.0.0/24, next to your static default route.

☐ Run **`show ip ospf neighbor`**. Expect one neighbour in **`FULL`**.

☐ Re-run two tests from your test table (the laptop browser to the care server, and one SSH test). Both must still pass.

☐ Screenshot **`show ip route`**. Name it **`T1_ospf_route.png`**.

☐ Add one sentence to the justification: static default route for the internet, OSPF for the ISP link.

If something breaks, remove it with **`no router ospf 1`** on both routers and restore the saved copy.

Task 5: TLS and keys (25 min)

5.1 Plain HTTP capture (5 min)

☐ Save this as **`note.json`** (change the client_id each time):

```
{"client_id":"demo-http-001","staff_id":"s1","patient_ref":"P123","note_tex
t":"Visit note for the TLS demo","created_at":"2026-11-11T10:00:00Z"}
```

☐ Open Wireshark. Choose the **Npcap Loopback Adapter**. If it is missing, capture on your LAN adapter and use your LAN IP in the URL. Start the capture with the filter **`tcp port 80`**.

☐ In PowerShell (use **`curl.exe`**, not **`curl`**):

```
$TOKEN = "<your write token>"
curl.exe -i -X POST http://localhost/prototype/sync.php -H "Content-Type: appl
ication/json" -H "Authorization: Bearer $TOKEN" --data-binary "@note.json"
```

☐ Stop the capture. Right-click a packet, choose Follow, then TCP Stream. You should see the note text and the token in readable form.

☐ Crop and save as **`T5_http_capture.png`**.

5.2 Make the certificate (4 min)

☐ Open a command prompt in **`C:\xampp\apache\bin`**.

☐ Run:

```
set OPENSSL_CONF=C:\xampp\apache\conf\openssl.cnf
openssl req -x509 -newkey rsa:2048 -nodes -keyout ..\conf\ssl.key\lab.key -out
..\conf\ssl.crt\lab.crt -days 365 -subj "/CN=localhost" -addext "subjectAltNam
e=DNS:localhost"
```

☐ If it says it cannot find the config file, check the path in the **`set`** line exists.

☐ Note for the write-up: self-signed lab certificate, no passphrase on the key, production would use a trusted authority.

5.3 Point Apache at it (5 min)

☐ Open **`C:\xampp\apache\conf\extra\httpd-ssl.conf`**.

☐ Set these two lines:

```
SSLCertificateFile "conf/ssl.crt/lab.crt"
SSLCertificateKeyFile "conf/ssl.key/lab.key"
```

☐ In **`C:\xampp\apache\conf\httpd.conf`**, check these are not commented out (no `#` in front): **`LoadModule ssl_module modules/mod_ssl.so`** and **`Include conf/extra/httpd-ssl.conf`**.

☐ In the XAMPP control panel, stop and start Apache.

☐ If Apache will not start, open **`C:\xampp\apache\logs\error.log`**, read the last line, and fix the path it names.

5.4 HTTPS capture (4 min)

☐ Start a Wireshark capture with the filter **`tcp port 443`**.

☐ Change the client_id in **`note.json`** to **`demo-https-001`**, then run:

```
curl.exe -k -i -X POST https://localhost/prototype/sync.php -H "Content-Type:
application/json" -H "Authorization: Bearer $TOKEN" --data-binary "@note.json"
```

The **`-k`** is needed because the certificate is self-signed. - ☐ Stop the capture, follow the TCP stream, and confirm it is unreadable. Crop and save as **`T5_https_capture.png`**. - ☐ Run **`openssl s_client -connect localhost:443 -brief`** from the same folder as before. Screenshot the TLS version line as **`T5_tls_version.png`**.

5.5 Make the endpoint HTTPS-only (3 min)

☐ In **`sync.php`**, change **`const REQUIRE_HTTPS = false;`** to **`true`**. Save.

☐ Run the plain HTTP request again. Expect HTTP 403. Screenshot as **`T5_http_refused.png`**.

☐ Run the HTTPS request again with a new client_id. Expect 201.

☐ In Git Bash, run the test script over HTTPS: **`sed 's/curl -s /curl -sk /' test_sync.sh > test_sync_tls.sh`**, then **`URL=https://localhost/prototype/sync.php TOKEN_OK=<token> TOKEN_READONLY=<token> bash test_sync_tls.sh`**. All rows should PASS. Save the output as **`T5_tests_over_tls.txt`**.

5.6 Prove revocation (3 min)

☐ Run this in phpMyAdmin or the MySQL shell: **`UPDATE api_tokens SET revoked=1 WHERE label='clinician';`**

☐ Repeat the valid request. Expect 401. Screenshot as **`T5_revoked_401.png`**.

☐ Put it back with **`UPDATE api_tokens SET revoked=0 WHERE label='clinician';`** and send again. Expect 201 or 200.

5.7 Key lifecycle table (copy this into your document, then change anything that does not match what you did)

Key	Generated	Stored	Access	Rotated	Revoked	Protected by
TLS private key	OpenSSL on the server	File in the Apache **`ssl.key`** folder, outside the web root	Server administrator only	Yearly, or at once on compromise	Replace the certificate (a CA would revoke it in production)	File permissions. Gap: lab key has no passphrase
API token	**`random_bytes`**	SHA-256 hash only	The device that holds it	30-day expiry	**`revoked`** flag	TLS, hashing
BitLocker recovery key	At encryption	Management system, not on the device	IT helpdesk	After each use	Decrypt or re-key	Admin role
SSH host keys	**`crypto key generate rsa`**	Router NVRAM	Network admins	Yearly, or on staff change	Zeroise the key	Management ACL, enable secret
Admin passwords	At configuration	Hashed in the config	IT admins	90 days, or on staff change	Remove the account	AAA, VTY ACL
Wi-Fi pre-shared key	On the access point	Password manager	IT	Yearly, or on loss	Change it	Gap: shared key, so WPA2-Enterprise in production

☐ Tick off: "What needs encrypting" (notes on device: disk encryption; notes in sync: TLS; admin access: SSH; Wi-Fi: WPA2; tokens: hashed).

Task 6: security case (25 min)

6.1 Define the case (5 min). Copy, then adapt:

☐ **What needs protecting:** visit notes and sign-in details cached on about 840 staff devices (420 staff, each with a laptop and a phone).

☐ **From whom:** someone who finds or steals a device, someone using an unlocked device, malware, and someone who steals or guesses an API token.

☐ **Why:** the notes are health and care information about vulnerable people, and the company has legal duties (UK GDPR, and the Caldicott principles).

☐ **If compromised:** harm or distress to clients, a report to the ICO within 72 hours where feasible, and loss of trust.

☐ **Assumptions:** every member of staff has a laptop and a mobile; a small IT team; a small number of on-premises servers; the care system is in the cloud.

6.2 Risk table (12 min). Scores are suggestions. Change them if you disagree.

Asset	Threat	Vulnerability	Control	L	I	Score	Residual (L x I)
Cached notes on a lost device	Loss or theft	Data readable if unencrypted or unlocked	Disk encryption with PIN, remote wipe, auto-wipe after N days offline	4	5	20	2 x 3 = 6
Cached records on any device	Another person or malware reads the cache	Large, long-lived cache	Cache only the day's caseload, clear after confirmed sync	3	4	12	2 x 3 = 6
Care system API	Stolen or guessable token	Weak authorisation	Scoped tokens, 30-day expiry, hashed storage, revocation	3	5	15	2 x 4 = 8
Sync traffic	Interception, tampering, replay	Insecure synchronisation	TLS only, unique note IDs, validation	3	4	12	1 x 4 = 4
Staff accounts	Misuse or compromise	Excessive permissions	Role-based least privilege, MFA, access review	3	4	12	2 x 3 = 6
Monitoring	A real attack is missed	Alert fatigue	Few high-value alerts, tiered triage	3	3	9	2 x 3 = 6

☐ Say how you scored: L and I run from 1 to 5, score is L x I, 15 and above is high.

6.3 Balance and residual risks (8 min)

☐ Use this table:

Control	Security gain	Cost to staff	Availability effect	Verdict
Remote wipe	Strong	None	Needs signal, so it cannot reach an offline device	Keep, and add auto-wipe after N days without sync
Short token life	Strong	More sign-ins	Notes written after expiry cannot sync	Allow offline entry, require a valid token to sync
Small cache	Medium	Fewer records offline	A dead zone may lack a needed record	Cache the day's visits only
MFA at sign-in	Strong	An extra step	Some methods need signal	Offline-capable unlock, and MFA at sync

☐ Write three residual risks, each with what would reduce it: 1. A device lost inside the offline window, before a wipe can arrive. Reduce with auto-wipe and a short window. 2. A stolen token used before it is revoked. Reduce with short expiry and monitoring for odd sync patterns. 3. A malicious insider with valid access. Reduce with least privilege, logging, and regular access review.

Task 7: architecture (25 min)

7.1 Draw it (12 min), in draw.io

☐ Draw three wide boxes, left to right, as trust zones: **Device zone**, **Internet and supplier cloud**, **Company LAN**.

☐ Put these boxes inside:

Device zone: staff laptop and phone (encrypted cache, MDM agent).

Cloud: identity provider with MFA, API gateway, care management platform, appointment system, log collector.

Company LAN: your Part A network (router, switch, servers, admin VLAN), device management.

☐ Draw six numbered arrows and label each with its control: 1. Device to identity provider: sign-in with MFA, over TLS. 2. Device to API gateway: note sync, scoped token, over TLS. 3. API gateway to care platform: validated, authorised request. 4. Care platform to appointment system: service-to-service, least privilege. 5. Device management to device: policy and remote wipe. 6. All components to log collector: security events.

☐ Show community staff reaching the cloud directly, not through the office LAN.

☐ Save as a PNG and name it `T7_architecture.png`.

7.2 Principles table (4 min), one line each

Principle	Where you applied it
Least privilege	Scoped API tokens; admin VLAN only for management; clinical VLANs limited to DHCP, DNS and HTTPS
Defence in depth	Disk encryption, token, TLS, ACLs and logging each stop a different attack
Separation of duties	The people who deploy changes are not the people who approve them; IT staff and clinical staff are on separate VLANs
Secure by design	HTTPS-only endpoint, parameterised queries, no stack traces
Minimise attack surface	Telnet off, unused ports in a blackhole VLAN, small cache, SMBv1 and remote registry disabled

7.3 Attacker paths (5 min)

Path	Countermeasure	Evidence
Stolen device, then cached notes	Encryption, lock, wipe	OS "after" file
Phished sign-in, then API	MFA, scoped tokens	Prototype tests 3 to 5
Compromised laptop on office Wi-Fi, then the servers	VLANs and ACLs	Network test table
Stolen API token	Short life, revocation	**`T5_revoked_401.png`**

7.4 Decisions and resilience (4 min)

☐ For each decision give: the business need, the risk it addresses, one alternative you rejected, and why. 1. Device encryption with remote wipe (rejected: no cache at all, because staff have poor signal). 2. VLAN segmentation (rejected: one flat network, because one compromised laptop could reach the servers). 3. API with scoped tokens and offline-safe sync (rejected: always-online access, because of poor connectivity).

☐ Single points of failure: one router, one switch, one uplink. Say what you would add (second router and uplink, spare switch).

☐ Write one short paragraph on how the design supports: security testing (test tables), monitoring (log collector), maintenance (patching and change control), resilience (offline sync, redundancy above) and future change (VLAN and subnet space left spare).

Task 8: policy and legal (25 min)

☐ Open **`policy.md`**. It has four policies and the rule, control and evidence map.

☐ **Check the facts (5 min).**

ICO: report "where feasible within 72 hours". Tell individuals "without undue delay" if the risk is high.

Internal 24-hour reporting is your own rule. Do not cite Article 33 for it.

Hedge the DSPT: applies if the company has access to NHS patient data and systems.

☐ **Adapt (10 min).** Replace the square-bracket values with what you built (7 days, 30 days, 6 months). Delete anything you did not do.

☐ **Evidence column (5 min).** Replace each entry with the real file or screenshot name from your **`evidence_log.txt`**.

☐ **Contractual line (2 min).** Add: "The cloud supplier contract must cover data protection, breach notification within [X] hours, and audit rights."

☐ **Gaps (3 min).** Keep the "Known gaps" list. Add anything you did not finish.

Justification (50 min)

Write it last. 900 to 1,100 words. First person. Use full sentences, not tables.

Order of writing (write the middle first):

Order	Section	Words	Starter sentences
1	Network design and why	200	"I segmented the network into six VLANs because..." / "I rejected a flat network because..."
2	Prototype, testing and findings	150	"I wrote a specification first, then..." / "My testing found..., which I fixed by..."
3	OS hardening and key management	150	"I hardened the clinical laptop against..." / "The key I considered highest risk was..."
4	Security case, architecture, trade-offs	150	"I chose lost devices as the case because..." / "The trade-off I accepted was..."
5	Policy and legal	100	"The duties that apply are..." / "I would evidence compliance by..."
6	Context and problem	100	"The organisation is a not-for-profit..., with 420 staff..."
7	Limits and residual risk	100	"The simulator cannot show..." / "What I did not finish is..."

Rules for each section:

☐ Give a reason for every decision, tied to the brief (for example "because staff work with poor signal").

☐ Name one thing you rejected.

☐ Refer to evidence by name ("test table row 7", **`T5_revoked_401.png`**).

☐ Say what the simulator cannot show: HTTPS in Packet Tracer is simulated, its DNS cannot forward, the lab certificate is self-signed.

☐ Include one real problem you troubleshot (for example "Bad VLAN list", DHCP mask mismatches, the NAT access list) and what you learned.

☐ Count words in Word (Review, then Word Count) every 10 minutes. Aim for 1,000.

Final checks and upload (20 min)

Use **`submission_guide.md`**. In short:

☐ 900 to 1,100 words.

☐ All eight topics have some evidence.

☐ Screenshots are cropped, labelled and within the page cap.

☐ No real passwords, tokens or keys visible. Search your files for **`enable secret`**, **`Bearer`** and your token.

☐ Every file opens. Names are as the portal expects.

☐ Unfinished items are listed as gaps.

☐ Upload. Check every file appears. Submission is final.

Cut list (use in this order if you are behind)

1. Task 0 (only needed if the pack requires dynamic routing).
2. Extra tests and attacks beyond Burp Repeater and one SQLMap run.
3. Write two policies in full, outline the rest.
4. Shorten the architecture to the diagram plus the attacker-path table.
5. Never cut: some evidence for every topic, and the justification.